

Planejamento e execução de políticas de tolerância ao risco

Toda organização lida diariamente com diferentes formas de risco. Em ambientes de TI, essas situações podem surgir de falhas técnicas, vulnerabilidades de segurança, interrupções operacionais ou até de mudanças repentinas no mercado e na legislação. Não é possível eliminar totalmente esses riscos, mas é viável definir até que ponto eles podem ser aceitos sem comprometer os objetivos do negócio. É justamente nesse ponto que entra a ideia de tolerância ao risco.

O planejamento e a execução de políticas de tolerância ao risco representam uma etapa estratégica da gestão, pois estabelecem parâmetros claros para a tomada de decisão. Essas políticas orientam líderes e equipes sobre quais riscos são aceitáveis, quais precisam de mitigação imediata e quais devem ser monitorados de perto. Dessa forma, criam um alinhamento entre a área de TI e a direção da organização, garantindo que a busca por eficiência e inovação caminhe lado a lado com a segurança e a continuidade das operações.

Para discutir essas questões, ao longo deste capítulo apresentaremos os conceitos fundamentais de tolerância ao risco, as formas de estruturar uma política clara e prática, os elementos que devem constar em relatórios e comunicações, além de exemplos de como integrar esse processo ao dia a dia da gestão de TI. Também será explorado o ciclo de vida da gestão de riscos, com etapas de identificação, avaliação, mitigação e monitoramento, sempre considerando que ajustes contínuos são necessários para manter a política atualizada e eficaz.

O objetivo é mostrar que a tolerância ao risco não deve ser vista como uma barreira à inovação, mas como um instrumento de equilíbrio. Quando bem planejadas e comunicadas, as políticas tornam-se um apoio importante na proteção de ativos críticos, além de garantir a confiança de clientes e parceiros e, ao mesmo tempo, abrir espaço para o crescimento sustentável do negócio.

1 Conceitos de tolerância ao risco

A ideia de tolerância ao risco parte do reconhecimento de que nenhuma organização está livre de falhas ou incertezas. Em ambientes de TI, os riscos podem variar desde uma simples indisponibilidade de serviço até ataques cibernéticos que afetam milhares de usuários. A tolerância representa o nível de risco que a empresa está disposta a aceitar em suas operações, sem comprometer sua estratégia ou colocar em perigo ativos críticos (Konopczyk, 2022).



IMPORTANTE

Risco: é a probabilidade de ocorrer um evento adverso que possa gerar impactos negativos em projetos, processos ou serviços, afetando objetivos, recursos ou resultados (Konopczyk, 2022).

Esse conceito funciona como um parâmetro para decisões e contribui para evitar tanto a negligência quanto o excesso de controle. Quando a tolerância é bem-definida, cria-se uma base para orientar investimentos em segurança, priorizar ações de mitigação e ajustar continuamente as práticas de gestão de TI. Em última instância, trata-se de equilibrar segurança, custo e oportunidade de inovação

1.1 Política de riscos

A política de riscos é o documento, muitas vezes concebido como um manual técnico, que traduz os princípios e diretrizes da organização em relação ao tratamento de incertezas. Sua função é estabelecer uma estrutura clara para que a gestão de riscos seja aplicada de maneira consistente em todos os níveis da empresa (Pegetti, 2023).

Essa política deve ser vista como um instrumento de governança que define papéis, responsabilidades e limites de aceitação de riscos. Além disso, serve de referência para auditorias internas, órgãos reguladores e, principalmente, para as equipes de TI, que precisam alinhar suas decisões às expectativas da alta gestão. O quadro 1 apresenta os elementos de uma política de riscos, contendo algumas descrições e exemplos de aplicação.

Quadro 1 – Elementos de uma política de riscos

ELEMENTO DA POLÍTICA DE RISCOS	DESCRIÇÃO	EXEMPLO DE APLICAÇÃO
Objetivo geral	Define o propósito da política e sua relação com os objetivos da organização.	Garantir que falhas em servidores não interrompam operações críticas de clientes de e-commerce.
Princípios e valores	Orientam a atuação da equipe na gestão de riscos.	Atuar sempre com transparência e registrar todas as ocorrências em sistema acessível aos gestores.
Limites de tolerância ao risco	Determinam até onde um risco pode ser aceito sem comprometer o negócio.	Aceitar indisponibilidade de até 15 minutos por mês em um sistema interno, mas não em sistemas de pagamento on-line.
Papéis e responsabilidades	Define quem responde por cada atividade no processo de gestão de riscos.	Equipe de TI monitora incidentes; alta gestão aprova investimentos em segurança; auditoria verifica conformidade.
Escopo	Delimita áreas, processos e ativos cobertos pela política.	A política abrange servidores de produção, rede corporativa e banco de dados de clientes, mas não cobre dispositivos pessoais de colaboradores.
Critérios de avaliação de risco	Estabelece parâmetros para medir impacto e probabilidade.	Classificação em níveis: baixo, médio, alto. Exemplo: perda de até 100 registros de clientes = risco médio.
Processo de comunicação	Define como e quando os riscos serão informados.	Relatórios trimestrais para diretoria; alertas imediatos para incidentes de segurança.
Documentação e registro	Estabelece onde os riscos e decisões serão documentados.	Utilização de plataforma de gestão de riscos integrada ao sistema de TI.
Monitoramento e revisão	Determina frequência de avaliação e atualização da política.	Revisão anual da política e testes semestrais de recuperação de desastres.
Alinhamento estratégico	Conecta a política de riscos à estratégia organizacional.	Investimento em backup em nuvem alinhado à estratégia de expansão internacional da empresa.

Fonte: elaborado pelo autor (2025).

1.1.1 Definição de gestão de riscos na organização

A gestão de riscos é um processo sistemático voltado para identificar, avaliar e tratar incertezas que possam impactar os objetivos da empresa. Esse processo envolve as seguintes etapas: análise do contexto, identificação de riscos, avaliação da probabilidade e do impacto, definição de estratégias de mitigação, monitoramento contínuo e comunicação dos resultados (Konopczyk, 2022).

No âmbito da TI, a gestão de riscos ganha um papel ainda mais relevante, pois envolve ativos intangíveis como dados, sistemas e infraestrutura crítica. A forma como esses riscos são tratados pode determinar a continuidade ou a interrupção de serviços essenciais. Um bom exemplo é quando uma falha em sistemas de pagamento on-line impede a conclusão de transações em uma empresa de comércio eletrônico. Além de gerar perdas financeiras imediatas, esse tipo de interrupção pode reduzir a confiança dos clientes e impactar a competitividade da organização no mercado.

1.1.2 Classificação e tipos de riscos

Segundo Konopczyk (2022), os riscos podem ser classificados de diferentes maneiras, de acordo com sua origem, natureza ou impacto. Os principais tipos de riscos são:

- **Riscos operacionais:** surgem quando há falhas em processos internos, sistemas ou infraestrutura. Por exemplo, uma pane em servidores que mantêm o sistema de e-mails corporativo pode interromper a comunicação entre equipes e atrasar entregas importantes.
- **Riscos estratégicos:** estão ligados a decisões de longo prazo que afetam o posicionamento da organização no mercado. Um caso comum ocorre quando uma empresa decide adotar uma nova

tecnologia sem avaliar sua maturidade, correndo o risco de perder competitividade, caso a solução não atenda às expectativas.

- **Riscos financeiros:** envolvem perdas monetárias, sejam diretas ou indiretas. Um exemplo prático é o pagamento de multas por descumprimento de contratos de nível de serviço (SLA), além de custos adicionais para restabelecer sistemas que ficaram fora do ar.
- **Riscos legais e regulatórios:** dizem respeito ao não atendimento de legislações ou normas vigentes. Considere, por exemplo, uma instituição que não cumpre requisitos da Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), e devido a isso pode sofrer penalidades financeiras e ter sua reputação prejudicada.
- **Riscos de segurança da informação:** abrangem ameaças como ataques cibernéticos, vazamentos de dados e acessos não autorizados. Um exemplo é a invasão de um banco de dados de clientes, que pode expor informações sigilosas e comprometer a confiança do público na organização.

Essa classificação ajuda a priorizar recursos, uma vez que cada tipo de risco demanda respostas específicas. Em muitas organizações, riscos regulatórios e de segurança da informação recebem maior atenção devido ao potencial de causar danos reputacionais e financeiros significativos.

1.1.3 Escopo da política: áreas, processos e ativos abrangidos

Uma política de riscos eficaz precisa deixar claro qual é o seu escopo de atuação. Isso significa especificar as áreas organizacionais, os processos de negócio e os ativos de TI que estarão sujeitos ao monitoramento.

O escopo pode variar bastante e algumas empresas optam por uma abordagem ampla, cobrindo todos os setores e ativos. Outras empresas iniciam de forma mais restrita, priorizando áreas críticas. Em uma

instituição financeira, por exemplo, o escopo tende a incluir desde a segurança das transações eletrônicas até a disponibilidade de canais de atendimento digital. Já em uma empresa de manufatura, pode incluir a integridade dos sistemas de automação e controle da produção.

Definir corretamente o escopo evita lacunas e reduz o risco de esforços dispersos. Além disso, permite alinhar expectativas entre os gestores de TI e a alta administração, estabelecendo um campo de atuação realista e mensurável.

1.1.4 Relatórios e comunicação sobre riscos

Relatar e comunicar riscos de forma transparente é tão importante quanto identificá-los e avaliá-los. Relatórios claros permitem que gestores e stakeholders compreendam a situação atual, tomem decisões informadas e acompanhem a evolução das ações de mitigação.

Esses relatórios podem variar em frequência e detalhamento, indo de painéis de acompanhamento em tempo real até relatórios trimestrais para a diretoria. O mais importante é que sejam objetivos, priorizem informações relevantes e utilizem uma linguagem acessível para diferentes públicos.

Além disso, a comunicação deve ser vista como um processo contínuo, não apenas como entrega de documentos. Reuniões periódicas, treinamentos e canais de feedback contribuem para fortalecer a cultura de riscos na organização e para que a política de tolerância ao risco seja compreendida e aplicada de forma consistente. Para melhor compreender esse contexto, o quadro 2 apresenta um exemplo de relatório de riscos em TI.

Quadro 2 – Relatório de riscos em TI

RISCO	CATEGORIA	NÍVEL DE RISCO	SITUAÇÃO ATUAL	STATUS
Falha em servidor de e-mail corporativo	Operacional	Alto	Quedas registradas no último trimestre	Em andamento
Vazamento de dados de clientes	Segurança da informação	Alto	Nenhum incidente, mas controles em revisão	Planejado
Multa por descumprimento de SLA	Financeiro	Alto	SLA cumprido nos últimos 6 meses	Controlado
Atraso em migração para novo ERP	Estratégico	Médio	Testes atrasados em 20 dias	Em andamento
Não conformidade com LGPD	Legal/regulatório	Alto	Falha em política de consentimento identificada	Crítico

Fonte: elaborado pelo autor (2025).

1.2 Definição de políticas de tolerância ao risco

A definição de políticas de tolerância ao risco permite que a organização estabeleça limites precisos sobre o nível de incertezas e impactos potenciais que está disposta a aceitar em seus negócios. Essas políticas funcionam como um guia prático para a tomada de decisões, alinhando estratégias de mitigação com a realidade operacional da empresa (Konopczyk, 2022).

Na prática, isso significa traduzir conceitos muitas vezes abstratos de risco em parâmetros objetivos, compreensíveis e aplicáveis no dia a dia da gestão. A clareza desse processo fortalece a confiança dos colaboradores e dos parceiros de negócio, pois transmite a ideia de que a empresa conhece seus pontos vulneráveis e sabe lidar com eles.

Apesar dos benefícios, políticas de tolerância ao risco maldefinidas podem gerar efeitos indesejados e comprometer a gestão como um todo.

Quando os limites de aceitação de riscos não estão claros, cada gestor ou equipe pode interpretar de forma diferente o que é aceitável, resultando em ações desalinhadas. Esse cenário abre espaço para decisões improvisadas e respostas reativas que podem aumentar custos e fragilizar a reputação da empresa.

Um exemplo é quando uma organização define de maneira vaga que aceita indisponibilidades curtas em seus sistemas. Contudo, sem parâmetros objetivos, como horas ou minutos, áreas técnicas podem tolerar interrupções de duas horas em um serviço crítico de e-commerce, enquanto a área comercial considera inaceitável qualquer parada superior a dez minutos. Essa falta de clareza gera conflitos internos e prejudica a experiência do cliente.

Outro caso comum é o da segurança da informação. Se a política não especifica qual nível de exposição de dados é tolerável, gestores podem minimizar incidentes de vazamento parcial, acreditando que estão dentro do aceitável, enquanto órgãos reguladores e clientes veem a situação como falha grave. O resultado pode ser a aplicação de multas ou a perda de contratos estratégicos.

Além disso, a formalização dessas políticas contribui para a consistência das ações, evitando que decisões sejam tomadas de forma improvisada ou apenas reativa a crises. Definir a tolerância ao risco, portanto, é um passo que equilibra ambição estratégica e segurança operacional, permitindo que a organização busque inovação sem comprometer sua estabilidade.

Para compreender as políticas de tolerância ao risco, consideremos que uma empresa de serviços em nuvem pode definir em sua política que aceita até duas horas de indisponibilidade por ano em seus sistemas críticos (parâmetro objetivo de tolerância). Isso significa que, se uma falha ocorrer dentro desse limite, será considerada aceitável e tratada dentro dos processos normais de manutenção. Porém, qualquer interrupção superior a esse período deve acionar planos emergenciais,

comunicação imediata aos clientes e até revisão do contrato com fornecedores. Dessa forma, a empresa equilibra inovação e eficiência, sem abrir mão da confiabilidade exigida por seus usuários.

1.2.1 Comunicação de políticas para stakeholders

Uma vez estabelecidas, as políticas de tolerância ao risco precisam ser claramente comunicadas a todos os públicos relevantes. Isso inclui desde os gestores internos até investidores, órgãos reguladores e parceiros de negócio. A comunicação pode utilizar a distribuição de documentos formais e precisa ser contínua, clara e adaptada ao nível de compreensão de cada grupo envolvido (Pegetti, 2023).

Por exemplo, para os colaboradores de áreas operacionais, a política pode ser traduzida em orientações práticas que mostrem como agir diante de situações de risco. Para os executivos, a mesma política pode assumir a forma de relatórios estratégicos que demonstrem o alinhamento das decisões com os objetivos de longo prazo. Já para stakeholders externos, como investidores ou clientes estratégicos, a comunicação deve reforçar a imagem de solidez e responsabilidade da organização (Pegetti, 2023).

A falta de clareza na comunicação pode gerar interpretações equivocadas, criando lacunas entre a política formal e a prática real. Por isso, a linguagem utilizada deve ser objetiva, evitando termos excessivamente técnicos e privilegiando exemplos que conectem a teoria à realidade da organização.

1.2.2 Ferramentas para documentação e acompanhamento

Para que as políticas de tolerância ao risco sejam efetivas, é indispensável documentá-las e acompanhar sua aplicação ao longo do tempo. Esse acompanhamento garante que a organização não apenas defina

seus limites de risco, mas também os monitore, avaliando se continuam adequados às mudanças no ambiente interno e externo.

Ferramentas como registros centralizados de riscos, matrizes de impacto e probabilidade e dashboards de acompanhamento são recursos frequentemente utilizados. Essas ferramentas ajudam a transformar dados em informações acessíveis e úteis para gestores e equipes. Além disso, permitem comparar a prática com os limites definidos na política, identificando quando ajustes são necessários.

Outro aspecto importante é a atualização periódica desses registros. O ambiente organizacional é dinâmico, e riscos que antes eram irrelevantes podem ganhar importância com mudanças no mercado, na legislação ou na própria estrutura da empresa. A documentação sistemática, acompanhada de revisões regulares, assegura que a política de tolerância ao risco permaneça viva e aderente à realidade.

Portanto, as ferramentas de acompanhamento não são apenas instrumentos técnicos, mas também mecanismos de governança que promovem transparência e responsabilidade. Quando bem aplicadas, contribuem para que todos os envolvidos compreendam os limites de risco da organização e atuem de forma alinhada a eles.

1.3 Estabelecimento de processos de gestão de riscos

Estabelecer processos de gestão de riscos é o passo que transforma diretrizes e políticas em ações concretas. Mais do que um conjunto de normas, trata-se de organizar etapas claras e práticas que ajudem a empresa a identificar ameaças, avaliar sua relevância, definir medidas de controle e acompanhar os resultados. Quando esse processo é bem estruturado, a gestão de riscos deixa de ser uma atividade reativa para se tornar parte do planejamento estratégico.

Um aspecto central é compreender que riscos não desaparecem completamente, mas podem ser reduzidos, transferidos ou monitorados. O processo, portanto, deve ser contínuo, adaptável e integrado ao dia a dia da organização, de forma que decisões importantes sejam sempre tomadas com base em informações confiáveis sobre exposição a riscos.

1.3.1 Ciclo de vida da gestão de riscos (identificação, avaliação, mitigação, monitoramento)

O ciclo de vida da gestão de riscos segue uma lógica sequencial, mas também cíclica, já que ao final de cada etapa é possível voltar à anterior, revisando e ajustando práticas. Esse ciclo, segundo a ABNT (2019), geralmente envolve quatro fases principais:

- **Identificação:** consiste em mapear os riscos que podem afetar a organização, considerando fatores internos, como falhas operacionais, e externos, como mudanças econômicas ou tecnológicas.
- **Avaliação:** após o mapeamento, os riscos são analisados em termos de probabilidade de ocorrência e impacto nos objetivos da empresa. Essa avaliação ajuda a priorizar os riscos mais críticos.
- **Mitigação:** nesta etapa são definidas e aplicadas medidas para reduzir a probabilidade ou o impacto dos riscos. Isso pode incluir controles internos, investimentos em tecnologia ou mudanças em processos.
- **Monitoramento:** como o ambiente é dinâmico, os riscos precisam ser constantemente acompanhados. Isso permite verificar se as medidas de mitigação estão sendo eficazes e se surgiram novos riscos relevantes.

Ao compreender e aplicar esse ciclo, a empresa cria uma rotina estruturada que fortalece sua resiliência e capacidade de adaptação.

1.3.2 Boas práticas baseadas em frameworks como ABNT NBR ISO 31000

Embora cada organização precise adaptar a gestão de riscos à sua realidade, frameworks internacionais oferecem boas práticas que servem de referência. A ABNT NBR ISO 31000 (2018) é um dos modelos mais conhecidos e estabelece princípios que ajudam a padronizar o processo de forma clara e eficiente.

Entre suas contribuições estão a ênfase na integração da gestão de riscos à cultura organizacional e a necessidade de envolvimento de todos os níveis hierárquicos. Outro ponto importante é a visão de que os riscos devem ser analisados não apenas como ameaças, mas também como oportunidades, já que a disposição para assumir certos riscos pode impulsionar a inovação.

1.3.3 Identificação de riscos não mitigados

Mesmo com processos bem-estruturados, sempre haverá riscos que não podem ser eliminados por completo. Esses riscos não mitigados precisam ser claramente identificados e registrados para que a organização saiba qual é sua real exposição.

Um exemplo comum ocorre em setores que dependem de fatores externos incontrolláveis, como oscilações econômicas globais ou desastres naturais. Nesses casos, a empresa não tem como eliminar o risco, mas pode monitorá-lo e preparar planos de contingência.

1.3.4 Ajustes contínuos para adequação à tolerância definida

A gestão de riscos não deve ser encarada como um projeto com início e fim, mas como um processo em constante evolução. Os ajustes contínuos são fundamentais para manter a política de tolerância ao risco alinhada às mudanças internas e externas da organização.

Isso pode envolver desde a revisão periódica das métricas de impacto até a atualização de relatórios, passando pela capacitação de equipes e pela introdução de novas ferramentas de monitoramento. O objetivo é garantir que os limites de risco aceitos pela organização estejam sempre compatíveis com sua realidade e com suas metas estratégicas.

Quando há esse movimento de atualização constante, a gestão de riscos deixa de ser apenas um mecanismo de proteção e passa a se tornar um diferencial competitivo, pois assegura que a empresa seja capaz de agir com segurança em um ambiente cada vez mais incerto.

Considerações finais

A gestão de riscos em ambientes de TI depende da clareza na definição de limites e da capacidade de alinhar tecnologia, processos e pessoas em torno de objetivos comuns. A política de tolerância ao risco cumpre esse papel ao estabelecer parâmetros que orientam decisões e evitam improvisos em momentos de incerteza.

Ao longo do capítulo, foi possível observar como a formalização dessas políticas dá suporte à governança, fortalece a comunicação entre diferentes áreas da organização e cria um ambiente mais preparado para lidar com incidentes. A aplicação de relatórios, o uso de ferramentas adequadas e a adoção de boas práticas permitem acompanhar a evolução dos riscos de forma estruturada e transparente.

Verificou-se ainda que a tolerância ao risco não é estática. Revisões periódicas e ajustes contínuos asseguram que a política permaneça coerente com as mudanças tecnológicas, regulatórias e estratégicas. Dessa forma, a gestão de riscos deixa de ser apenas uma obrigação regulatória e passa a contribuir para a estabilidade e a competitividade da organização.

Em um mercado cada vez mais digital e dinâmico, organizações que definem e aplicam políticas de tolerância ao risco transmitem confiança, preservam sua reputação e mantêm sua capacidade de inovar sem comprometer a segurança e a continuidade dos serviços.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (2018). **ABNT NBR ISO 31000:2018** – Gestão de riscos — Diretrizes. Rio de Janeiro, 2018.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO/IEC 27005:2019**: tecnologia da informação: técnicas de segurança: gestão de riscos de segurança da informação. 3. ed. Rio de Janeiro, 2019.

KONOPCZYK, M. G. **Riscos, auditoria e resposta a incidentes**. São Paulo: Editora Senac São Paulo, 2022.

PEGETTI, A. **Gestão da segurança da informação**. São Paulo: Editora Senac São Paulo, 2023.

